TABLETOP / AGENTIC KUBERNETES GUARDRAILS

FROM INTENT TO ENFORCEMENT

Quarantine Mode

Incident containment on a shared Kubernetes platform



Co-presenters: Milind Gunjan / Vivek Mayuranathan

October 26, 2026 · 4:30–5:30 PM · Views are our own

What this workshop builds

WHAT

An agent proposes a change set from security intent for human review: policies, tests, expiring exceptions and a phased rollout.

WHY

Contain harmful access on shared infrastructure
while essential services keep running.

Quarantine Mode: tighten selected controls, bound disruption and define recovery tests.

The environment in plain language

Kubernetes manages application packages, called containers, across machines.
Payment services and automated agents share this platform.

Application copies	Pods: running units. Replicas: copies.
Resource groups	Namespaces: named groups, such as payments.
Workload identity	ServiceAccount: identity for management API requests.

Multiple services share infrastructure and dependencies.
A restriction for one can affect another.

Kyverno checks proposed changes

Kyverno checks a requested change before it takes effect.
That checkpoint is called admission.

Request	Start an application copy with privilege escalation.
Rule	New application copies must disallow privilege escalation.
Deny mode	Refuse that covered request.

An application already running keeps running. Traffic, management access and agent tools need their own controls.

Your table’s task

Decide what can proceed and what evidence is still missing.
Write before each reveal. Revise beside your original answer.

YOUR RECORD ON PAGE 6

Intent and approval decision
Exception and rollout conditions
Containment order and recovery tests

YOUR TABLE ROLES

Lead: states the decision
Recorder: writes page 6
Analyst: checks the evidence
Reviewer: raises a concern

Materials: case cards, the page 6 record and sealed evidence.
Milind: compiler/policy demo. Vivek: reviews/reveals. Both co-present the debrief.

Four prepared scenarios

A	**Library update**	A library update and unexpected payments traffic
B	**Support assistant**	A ticket-reading assistant and unexpected tool activity
C	**Unexpected changes**	An ops agent changes application copies without a ticket
D	**Credential access**	A monitoring identity lists credential records across groups

Choose as a team. Keep the sealed updates closed until the round opens.

Operational constraints

Availability	Keep two healthy application copies and required connections.
Evidence	Preserve evidence and record every approval.
Velocity	Continue safe delivery while affected changes pause.
Containment	Stop suspected exposure and justify the service cost.

Record your case, roles, constraint and minimum service on page 6.

01

Define the security requirement.



Write one intent on page 6.
Name the forbidden behavior and preserved dependency.

Typed decisions and deployment authority

Owner	Responsibility
Decision provider	Choose a typed control, dependency or next action
Code and templates	Fill approved values, validate the spec and render YAML
Tools	Observe workloads and simulate admission outcomes
Human reviewer	Resolve missing controls, approve exceptions and deploy

Intent → reviewable proposal

“Prevent privilege escalation by workloads in the payments namespace.”

Control: deny_privilege_escalation
Templates produce a Kyverno policy. Fixtures show its effect.

The real System-1 model failed the current live-demo gate.
This enforcement demonstration uses a supplied reference spec.

Unresolved enforcement requirements

Intent clause	Proposal status
Limit east-west communication	Egress-profile policy
Prevent privilege escalation	Privilege policy
Restrict Kubernetes API access	Unimplemented. RBAC handover required.
Avoid disruption and expire exceptions	Rollout and exception process

Simulation evidence is limited to the fixtures exercised.

Record your review decision

APPROVE

MODIFY

REJECT

ESCALATE

One control to keep or change.

One missing test that could change your decision.

Exception approval is unverified

The request cites operational need but provides no verified approver or expiry.

VERIFY THE APPROVER. NARROW THE SCOPE. SET THE EXPIRY.

22–26 MINUTES / TEAM TASK

Audit. Warn. Deny.

Mode	Admission behavior	Review question
Audit	Allow and record	Is exposure acceptable while we observe?
Warn	Allow and warn	Who will act on the warning?
Deny	Refuse the change	What legitimate workload could break?

Choose a mode per control and write promotion criteria.

Quarantine Mode

Level	Control change	Operational effect
Q0 Normal	Baseline guardrails	Normal service
Q1 Freeze	Freeze covered agent writes and new exceptions	Running Pods remain
Q2 Constrain	Capture evidence, constrain suspect network and rotation	Clean capacity can serve
Q3 Isolate	Remove remaining suspect network allowances	Degraded service may follow

03

Plan scoped containment.

Open the sealed update on page 7.
Number actions and state the service floor.



Reassess with additional evidence

REVISE THE PLAN / ESCALATE / JUSTIFY NO CHANGE

Record which new evidence changes the scope or action order.

Validate the containment assumptions

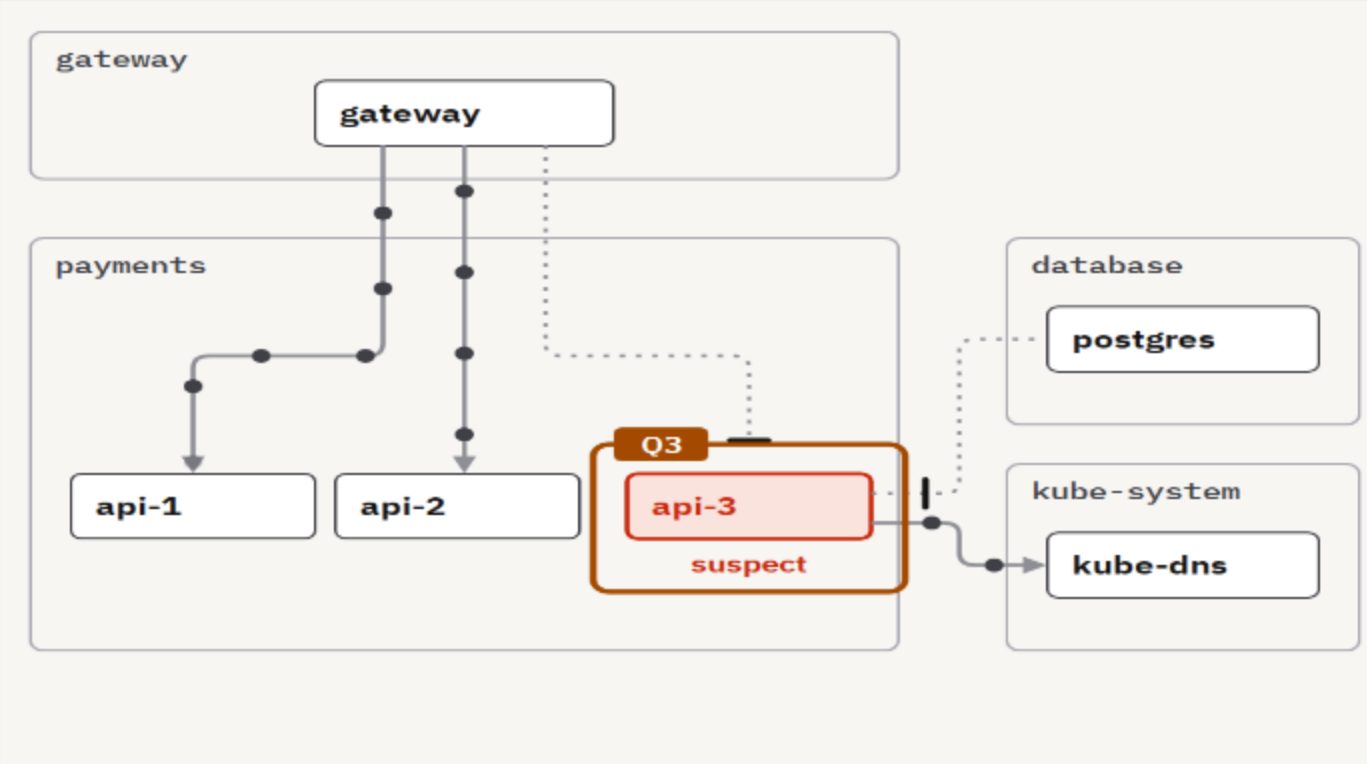
NETWORK Does deny-all remove an existing allow?

RECOVERY Can eviction preserve evidence and healthy capacity?

AUTHORITY Which identity or API path can bypass your plan?

Real k3s observations. Fictional incident. Recorded, not live.

Is the suspect isolated?

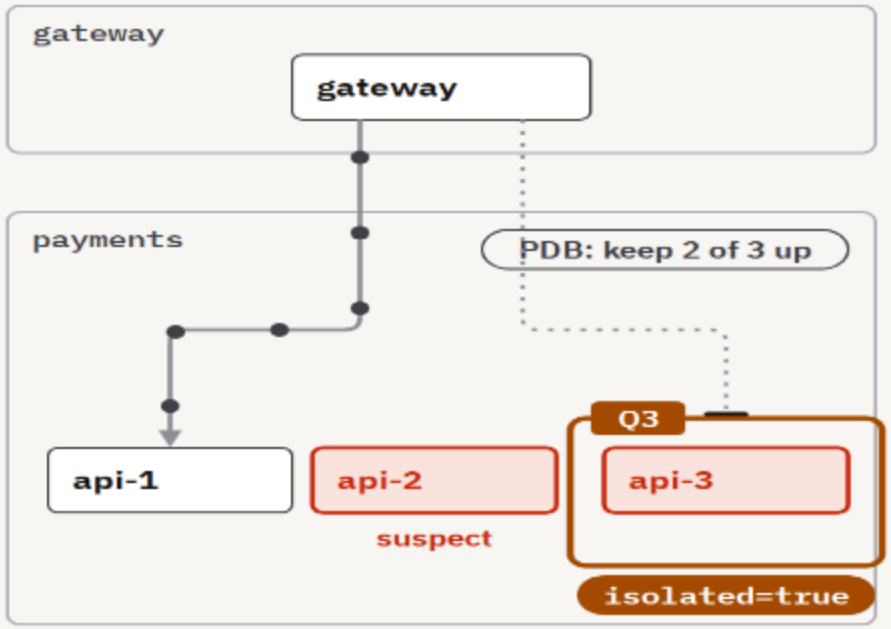


Q3 is declared.
Look at the DNS path.

RECORD YOUR DECISION. STATE THE SUPPORTING EVIDENCE.

Recorded k3s observations; simplified workload names. Scenario context is fictional.

Can both suspect application copies be removed?

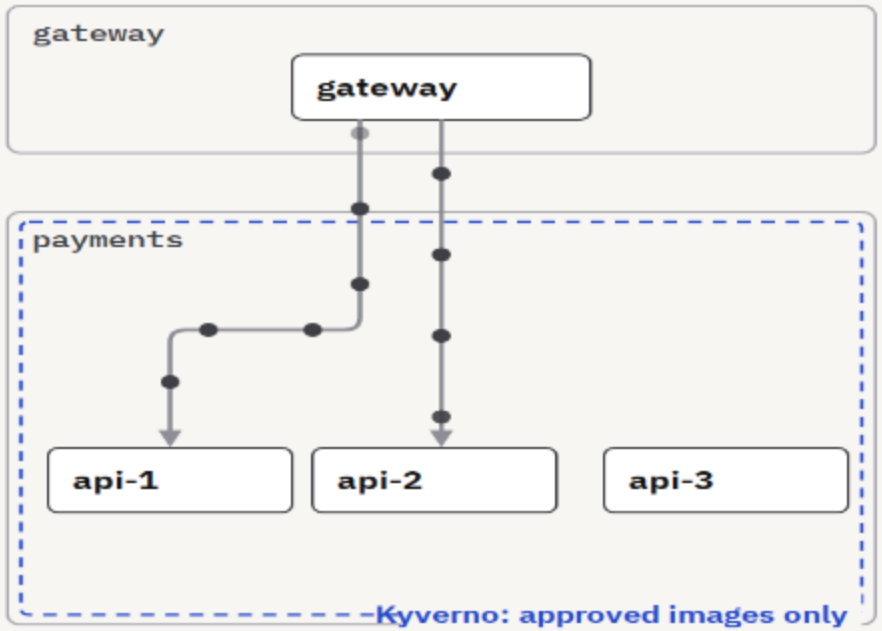


Three serving copies. Keep two available.

RECORD YOUR DECISION. STATE THE SUPPORTING EVIDENCE.

Recorded k3s observations; simplified workload names. Scenario context is fictional.

Does Q2 cover the debug request?

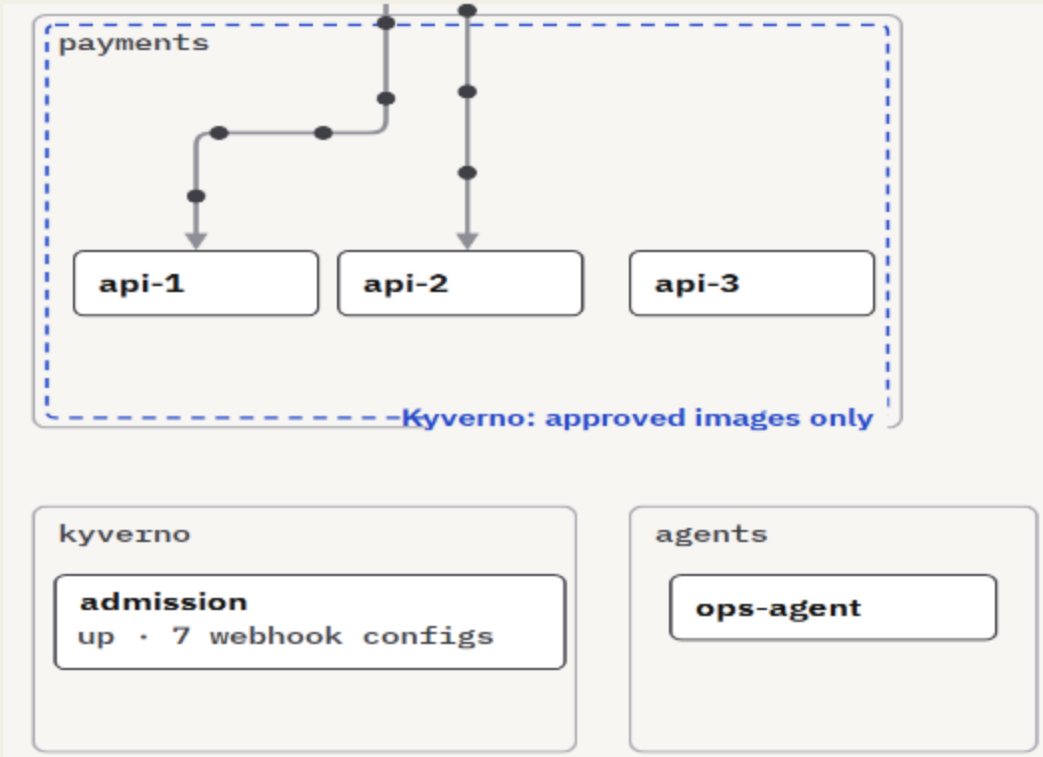


Only approved images may start in payments.

RECORD YOUR DECISION. STATE THE SUPPORTING EVIDENCE.

Recorded k3s observations; simplified workload names. Scenario context is fictional.

Can this identity disable admission?



Its role can scale any Deployment.

RECORD YOUR DECISION. STATE THE SUPPORTING EVIDENCE.

Recorded k3s observations; simplified workload names. Scenario context is fictional.

Review findings and unresolved requirements

Case	What changes the response
A	The updated image is present on multiple replicas
B	The assistant follows injected instructions through tools
C	A human executes changes outside the agent identity scope
D (lab)	Copied credential still reads Secrets after Pod quarantine

Trained model proposal

Requirement	Selected control / routing	Score
Network restriction	Privilege escalation	0.8986
Privilege escalation	Privilege escalation	0.8574
Kubernetes API access	Human review	0.5895
Rollout and expiry	Privilege escalation	0.9107

One privilege policy. Six privilege tests pass.

Which requirements lack enforcement evidence?

Passing privilege tests leave the proposal incomplete

6 / 6

Pod CREATE privilege tests

Network	Wrong control selected
API access	Human disposition required
Rollout / expiry	Wrong control selected

Record the enforcement owner and the evidence required to proceed.

MEASURED PILOT / THREE-RUN WORKFLOW MEDIANS

Model and workflow evaluation

JEV 1.13	CLAUDE OPUS 5.5	LAYA / ZERO-SHOT
30/33	**32/33**	**16/33**
1.82 s / run	**24.18 s / run**	**0.41 s / run**
$0.00019 / run	$0.03795 / run	$0 API* / run
Guardrail generated	**Guardrail generated**	**No guardrail generated**

33 author-labelled choices. Review/deployment excluded. *Local compute unpriced; workflow incomplete.
Small pilot; confidence definitions differ. No production superiority claim. Full metrics in backup.

04

Define recovery criteria.

On page 6, name the exit test, who can lift quarantine and the rollback condition.



Identify a requirement.
Assign its owner.
Specify acceptance evidence.

Choose one unresolved control boundary in your environment.
Document the evidence needed before approving enforcement.

Patterns to adapt across Kubernetes

github.com/mgunjan/sc2632-tabletop

Policy templates and fixture tests
Evidence capture and Quarantine levels
Four incident cases and recorded lab results

Apache-2.0 source, public repository.
Validate identity, CNI behavior and policy support on your platform.

Fallback: generated policy excerpt

kind: ValidatingPolicy
name: deny-privilege-escalation
validationActions: [Deny]

The policy rejects privileged containers.
Human review approves the generated file before deployment.

Provenance: model = none (spec supplied)

Fallback: fixture admission outcomes

Workload	Policy result
payments-api	Passes privilege and egress checks
backup-job	Would block under the egress-profile policy
report-runner	Registry violation at Audit, admitted
backup-job with exception	Egress check skips the matched exception

Case D: copied credential response

Change	Copied Kubernetes credential	Preserved access
Broad binding	Outside Secret GET/LIST: 200	Named Secret and ConfigMap: 200
Pod quarantined	Outside Secret GET/LIST: 200	Stand-in HTTP health available
RBAC narrowed	Outside Secret GET/LIST: 403	Required named GETs: 200
Old bound Pod deleted	Old credential: 401	Replacement credential: 200

Stand-in health only. External application-key rotation remains required.

Training and classical baselines

Candidate	Correct / 27	Selected / 27	Wrong selected
TF-IDF + logistic regression	20/27	8/27	0
Base Laya	12/27	2/27	0
Trained Laya	12/27	16/27	5

480 synthetic training states. Same task and runtime option order.

Small author-labelled pilot. Confidence needs independent validation.

Setup and total operating cost

Cost component	Hosted API	Local model
Setup	Keys, billing, network, workspace	Runtime, weights, device and memory
Per-run inference	Metered token charges	Owned compute and operations
Shared engineering	Compiler, tests, credentials and observability	Compiler, tests, credentials and observability
Human review	Uncertainty and unmet intent	Uncertainty and unmet intent

One extra minute of review can exceed the API cost savings.

Full comparison: quality and confidence

Metric	Jev 1.13	Opus 5.5	Laya
Correct choices	30/33	32/33	16/33
Decision latency	0.17 s HTTP	2.37 s HTTP	0.09 s in-process
Selected at score 0.6	26/33	33/33	1/33
Wrong among selected	0/26	1/33	0/1
Scenario A time/run	1.82 s	24.18 s	0.41 s
API cost/run	$0.00019	$0.03795	$0 API; compute unpriced

33 scored labels. Small pilot; confidence definitions differ. Laya generated no guardrail.